Projet DORA : mise en conformité d'IvoirPay

Étude de cas réalisée dans le cadre d'un Master GRC. IvoirPay SAS, ses collaborateurs, ses prestataires et ses chiffres sont fictifs ; les références réglementaires sont réelles.

1. Contexte

IvoirPay est une fintech française qui permet aux commerçants d'accepter les paiements par carte en ligne et en magasin. Agréée comme établissement de paiement par l'ACPR, elle réalise 38 M€ de chiffre d'affaires et traite environ 1,9 Md€ de flux par an pour 4 200 marchands. Son activité repose sur l'informatique et sur dix prestataires TIC (hébergement cloud, processeur de paiement, logiciel de cantonnement des fonds, vérification d'identité, SOC externalisé, authentification forte, sauvegarde, messagerie, outil de tickets, forge logicielle).

Le règlement DORA s'applique depuis le 17 janvier 2025, mais IvoirPay n'a lancé aucun chantier dédié. En mars 2026, une panne de cinq heures de son processeur de paiement a bloqué 30 % des marchands, sans que personne ne sache s'il fallait la déclarer à l'ACPR ni dans quel délai. La direction générale demande un état des lieux chiffré et une feuille de route.

2. Mission

En tant que chargé de mission conformité DORA, rattaché à la direction de la conformité, il faut mesurer l'écart entre la situation d'IvoirPay et les exigences du règlement, puis proposer un plan d'actions priorisé à présenter au comité de direction. Les informations disponibles sont les entretiens avec les responsables (DSI, RSSI, conformité, risques, opérations, juridique), l'inventaire des contrats prestataires et le retour d'expérience de la panne de mars 2026.

3. Travail demandé

Le livrable est un classeur Excel de suivi. Chaque tâche correspond à un onglet.

1. **Fonctions critiques (onglet FCI) :** identifier les fonctions de l'entreprise, noter l'impact d'un arrêt de 1 à 4 (financier, clients, réglementaire), en déduire les fonctions critiques ou importantes et fixer leurs RTO et RPO (art. 8 et 12).
2. **Analyse d'écarts (onglet Gap analysis) :** décliner DORA en exigences vérifiables sur les cinq piliers, évaluer chacune (0 absent, 1 partiel, 2 conforme, N/A), décrire l'écart et le prioriser.
3. **Registre d'information (onglet Registre) :** construire un extrait du registre au format de l'ITS 2024/2956 : prestataires, contrats, sous-traitance, substituabilité et solutions de sortie (art. 28 et 29).
4. **Revue des contrats (onglet Art30) :** vérifier dans chaque contrat critique la présence des clauses de l'article 30 et calculer un taux de conformité par contrat.
5. **Classification des incidents (onglet Classif incidents) :** créer un outil qui applique les critères du RTS 2024/1772 et calcule les échéances de notification (4 h, 72 h, 1 mois), puis le tester sur deux incidents.
6. **Programme de tests (onglet Plan tests 2027) :** planifier les tests de résilience de 2027 pour couvrir chaque fonction critique au moins une fois par an (art. 24 et 25).
7. **Plan d'actions (onglet Plan actions) :** traduire les écarts en actions avec responsable, échéance, charge en jours-homme et priorité.
8. **Synthèse (onglet Synthèse) :** consolider automatiquement le taux de conformité par pilier, les écarts prioritaires et l'avancement du plan.

4. Hypothèses

- IvoirPay n'est pas une microentreprise : le régime complet s'applique, pas le régime simplifié de l'article 16.
- IvoirPay n'a pas été désignée par l'ACPR pour un test de pénétration fondé sur la menace (TLPT) : l'exigence est non applicable.
- L'autorité compétente est l'ACPR.
- Chaque note doit pouvoir être justifiée par une preuve ; une pratique non documentée vaut au mieux un niveau 1.
- Le plan d'actions doit être réalisable par une équipe réduite d'ici fin juin 2027.

5. Textes de référence

- Règlement (UE) 2022/2554 (DORA)
- RTS (UE) 2024/1774 : cadre de gestion du risque TIC
- RTS (UE) 2024/1772 : classification des incidents
- RTS (UE) 2025/301 et ITS (UE) 2025/302 : déclaration des incidents
- ITS (UE) 2024/2956 : registre d'information
- RTS (UE) 2024/1773 et RTS (UE) 2025/532 : politique prestataires et sous-traitance

6. Résultats

- Taux de conformité global de 36 %, le plus faible sur les prestataires TIC (22 %) et les incidents (25 %).
- 6 fonctions critiques ou importantes sur 10, dont les paiements carte (RTO 1 h, RPO nul).
- 17 écarts de priorité 1, dont l'absence de fonction de contrôle indépendante, de grille de classification des incidents et de stratégies de sortie.
- Contrats critiques conformes de 30 % à 77 % à l'article 30, et un risque de concentration caché : le processeur de paiement est hébergé chez le même fournisseur cloud qu'IvoirPay.
- Plan de 20 actions représentant 192 jours-homme d'ici juin 2027.